



Zoziel Freire

Ransomware vs EDR
Inside Attackers' Mind

Disclaimer

Nothing I say here represents my company,
that is, all analysis is my responsibility.

Purpose

The goal was to create a script to build a Threat Simulator, but as the studies progressed, it ended up turning into malware to deceive something.

Topics

- Ransomware Overview
- Detection and Prevention Tools
- Custom Ransomware
- Persistence
- Case Study
- Conclusion and Recommendations

Whoami ?

Whoami ?

- Bachelor's degree in Information Systems
- Postgraduate degree in Forensic Computing
- Postgraduate degree Cyber Security
- Forensic Specialist
- Incident Response Specialist
- Passionate about Malware Analysis and Development
- Fan of Music, Chaves, and Chapolin



Contributions to the community

hackbahia



ADINT
• Cyber Intelligence Institute •



NerdZão



caju sec
SECURITY CONFERENCE





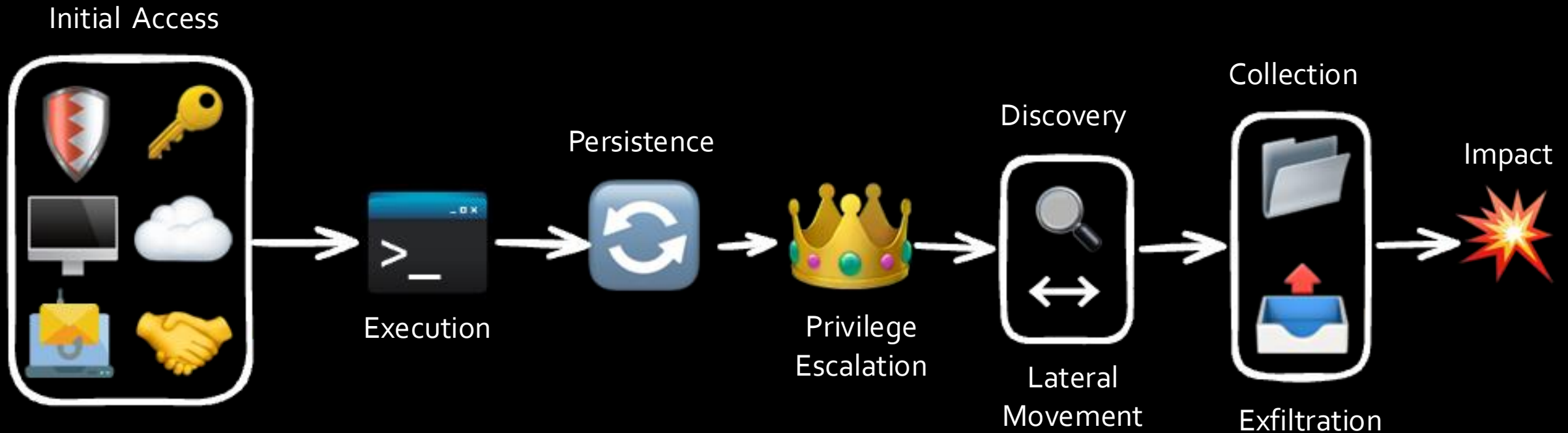
Ransomware Overview

What is Ransomware?

Ransomware is a type of malware that encrypts a victim's data or blocks access to systems, demanding a payment to restore access or release the data.



Ransomware Kill Chain



Ransomware Features

- File Scans
- Encryption
- External Communication (File Transfer)
- Creation of a ReadMe.txt
- Wallpaper Change
- Persistence

Detection and Prevention Tools

Endpoint Detection Response

Continuous Monitoring / Data Collection:

Process Activity

What programs are running and their behavior

File System Changes

Files being added, modified, or deleted

Network Activity

Connections being made, protocols used, etc

User Activity

Logins, command-line actions, etc

Endpoint Detection Response

Threat Detection:

Signature-Based Detection

EDR systems may use known threat signatures to identify malware

Behavioral Analysis

EDRs often use machine learning, artificial intelligence, and heuristic algorithms to detect anomalies in endpoint behavior

Endpoint Detection Response

Threat Detection:

Indicators of Compromise (IOCs)

The EDR will look for known IOCs (e.g., suspicious file hashes, malicious IP addresses, etc.) to identify possible threats

Root Cause Analysis

EDRs can trace the sequence of events leading to suspicious activity, helping security teams understand how an attack occurred and its impact.

Endpoint Detection Response

Alerting:

Real-Time Alerts

When suspicious activity is detected, EDR generates alerts and prioritizes them based on the severity

Contextual Information

Alerts include details about the affected endpoint, the nature of the threat, and recommended actions for response.

Endpoint Detection Response

Response:

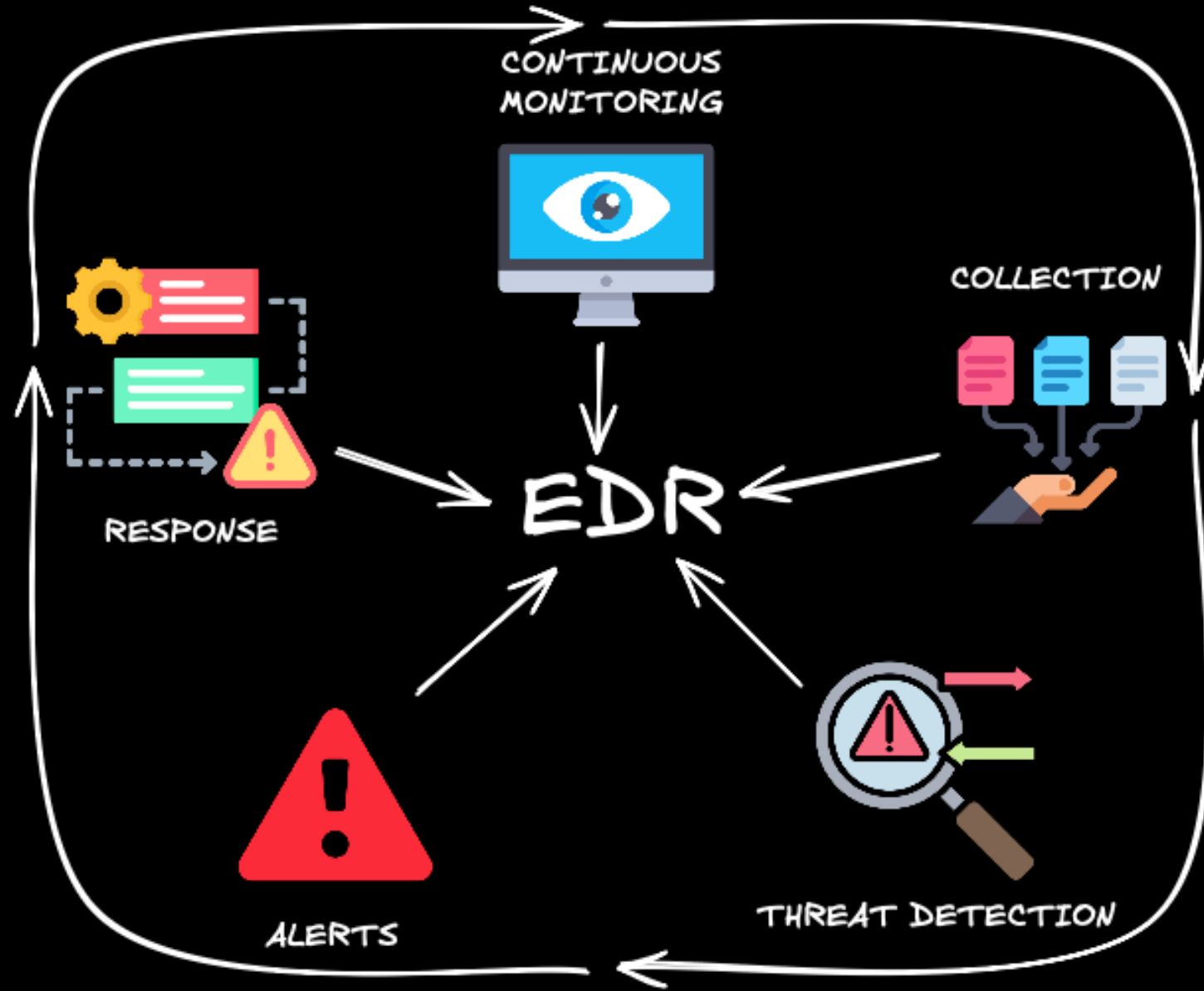
Isolation

Compromised endpoints can be quarantined to prevent the spread of malware or lateral movement within the network.

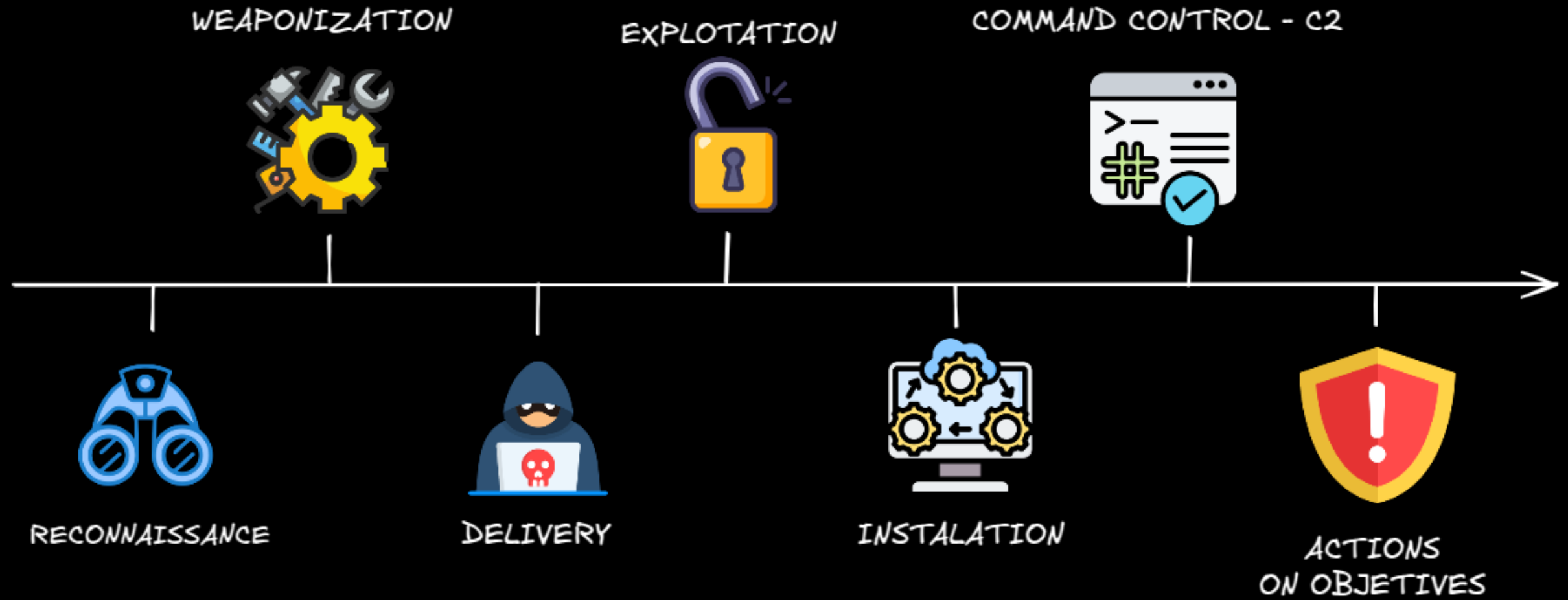
Remediation

EDR solutions provide tools to terminate malicious processes, delete malicious files, or roll back changes made by malware.

Endpoint Detection Response



Cyber Kill Chain



Breaking Cyber Kill Chain



Paid registration

2

20 posts

Joined

11/15/24 (ID: 181922)

Activity

seo

Car warranty

0

Posted 38 minutes ago (edited)

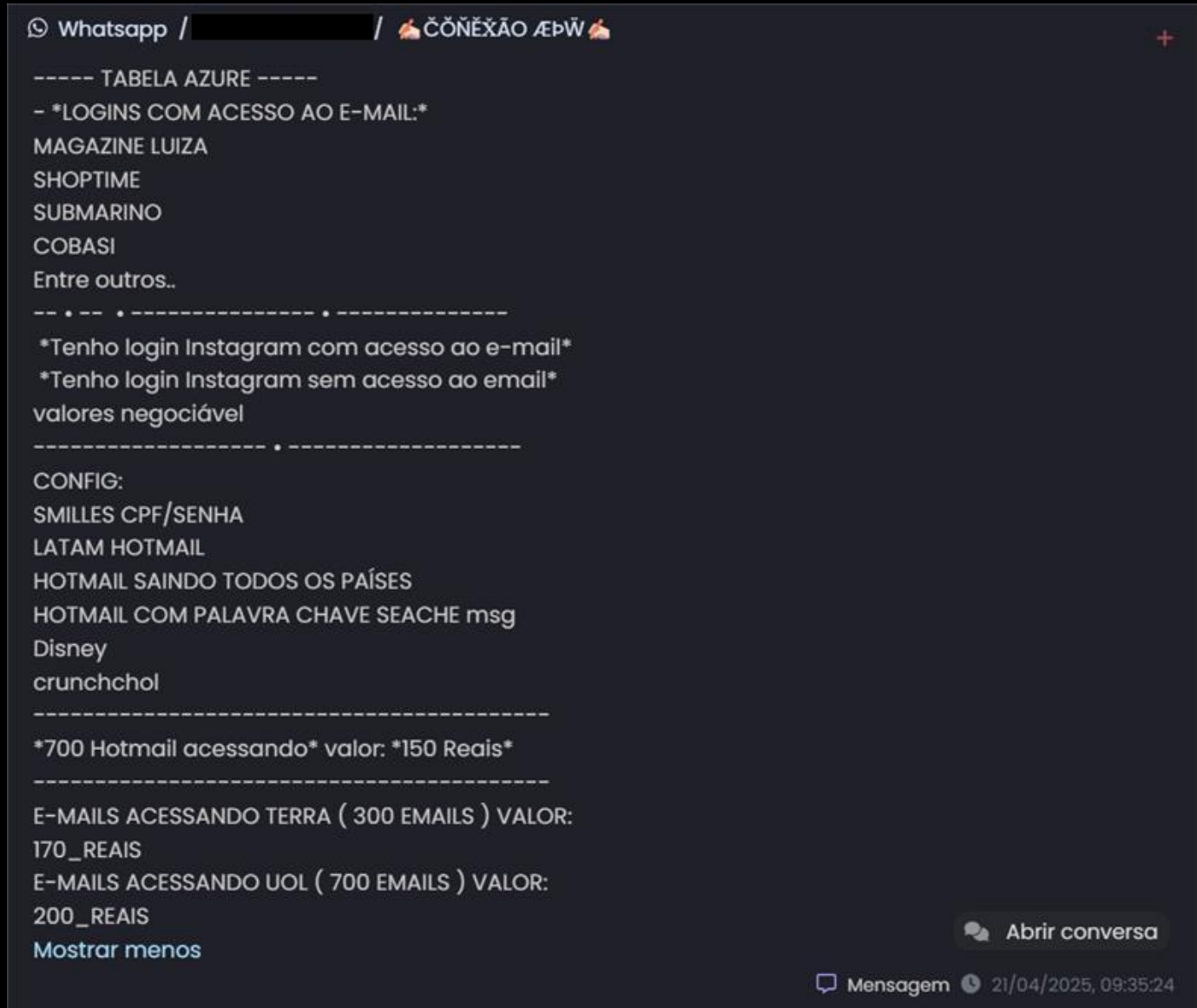
betfair.es (log:pass/mail:pass) \$20-50 valid
betfair.ro (log:pass/mail:pass) \$20-50 valid
betfair.it (log:pass/mail:pass) \$20-50 valid
pokerstars.es (log:pass/mail:pass) \$20-50 valid
pokerstars.se (log:pass/mail:pass) \$20-50 valid
pokerstars.it (log:pass/mail:pass) 20-50 \$ valid
service.sim.de (log:pass) 3-5 \$ valid
winsim.de (log:pass) 3-5 \$ valid
handyvertrag.de (log:pass) 3-5 \$ valid
premiumsim.de (log:pass) 3-5 \$ valid
simplytel.de (log:pass) 3-5 \$ valid
smartmobil.de (log:pass) 3-5 \$ valid
maxxim.de (log:pass) 3-5 \$ valid
yourfone.de (log:pass) 3-5 \$ valid
deutschclandsim.de (log:pass) 3-5 \$ valid

Checker for everything is available! I send all screenshots and proofs!

There are profiles on all boards and there are also reviews

Edited 37 minutes ago

Breaking Cyber Kill Chain



Breaking Cyber Kill Chain

≡ tecmundo

SECURITY

Does hacker attack on the Central Bank's partner affect customers? Experts explain

Cybercriminals will have diverted at least R\$ 400 million during the attack on C&M Software systems, according to initial reports.

Economy

Hackers breach C&M Software's system; impact is in the millions.

According to the Central Bank, the institutions' access to the infrastructure operated by the provider C&M has been shut down.

Mariana Andrade

02/07/2025 10:50updated 02/07/2025 10:54

METRÓPOLES

"This wasn't a zero-day attack or a complex vulnerability, but rather basic flaws in identity and access management. The attackers used valid credentials to operate from within the trusted environment."

Custom Ransomware

Customizations

- Developers
 - Python (Script and Binary)
 - Java Languages (Script)
- Cryptography
- Directory Specific | Full Scan
- ReadME | Wallpaper
- Persistence (LaunchD | Registry | crontab)

Customizations

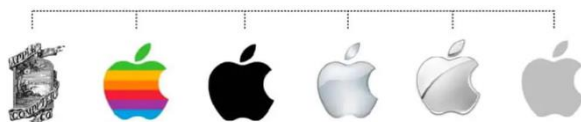
- Why use Python and Java?
 - Dependency for several applications, especially banks
 - Widely used by developers
 - Rapid development
 - Popularity



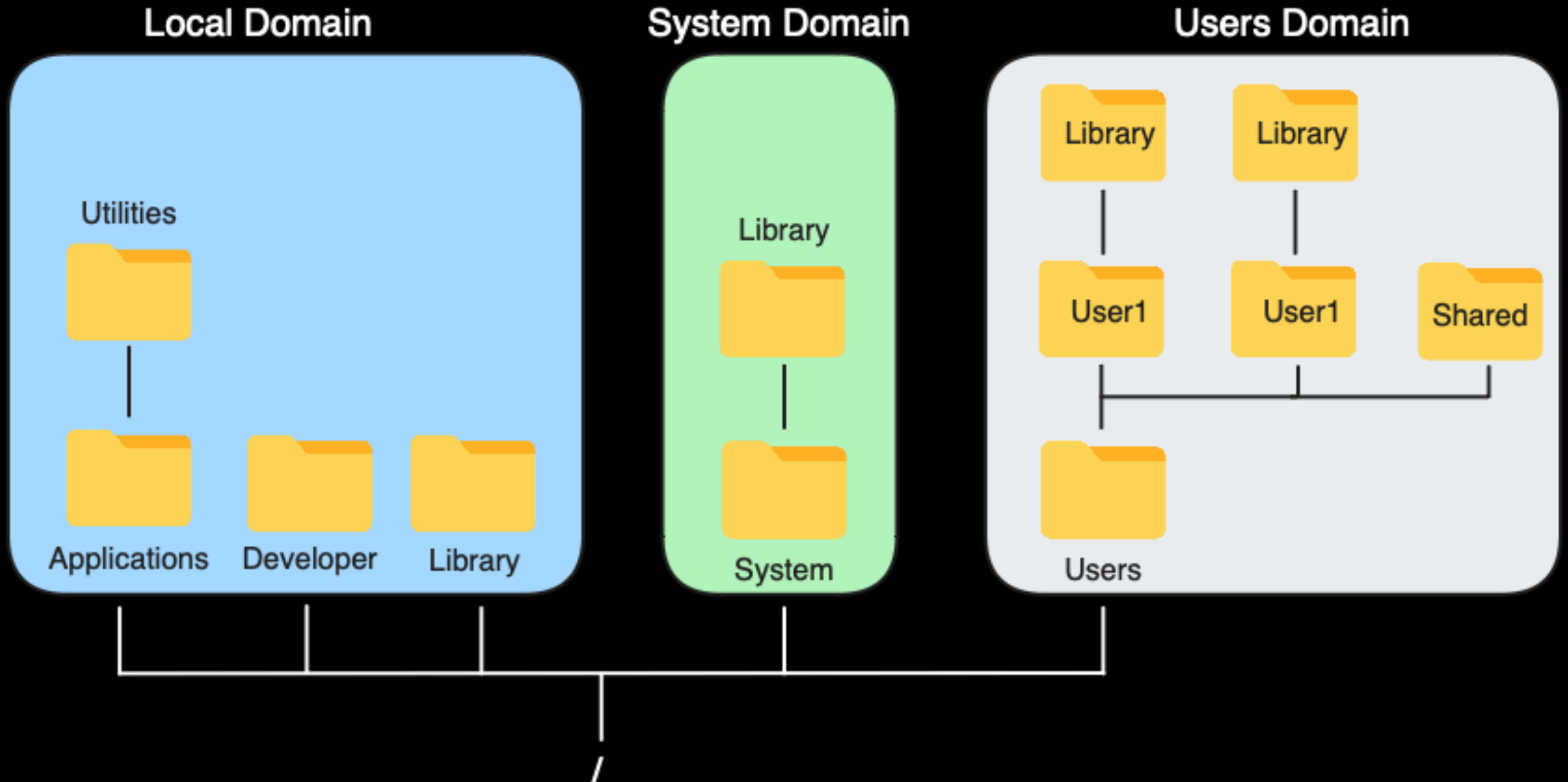
Persistence



Version / Name	Year	Highlight
System 1.0	1984	First version of the Macintosh. Introduction of the graphical interface with a mouse. Revolution in user experience.
System 7	1991	Milestone of the classic era. Support for multitasking, color, and networking. Foundation of Macs throughout the 1990s.
Mac OS X 10.0 "Cheetah"	2001	Start of the modern era. New Unix-based foundation (NeXTSTEP), Aqua interface, and improved stability.
macOS 10.15 "Catalina"	2019	End of support for 32-bit apps. iTunes split into separate apps. Technical groundwork for the architecture transition.
macOS 11 "Big Sur"	2020	Full interface redesign. Transition from Intel to Apple Silicon (ARM/M1). New era for Macs.
macOS 26 "Tahoe"	2025 (Expected)	Continuation of the ARM era. Deep integration with iPhone, AI, and the Apple ecosystem. Vision for the future of macOS.



The Local MacOS file system



MacOS Launchd

- Third-party agents only apply to the currently logged-in user.
- LaunchAgents do not require permissions, making them the easiest form of persistence to install on a MacOS system.

MacOS Launchd

Where to Look:

- **~/Library/LaunchAgents/**
- /System/Library/LaunchAgents/
- /Library/LaunchAgents/

File plist

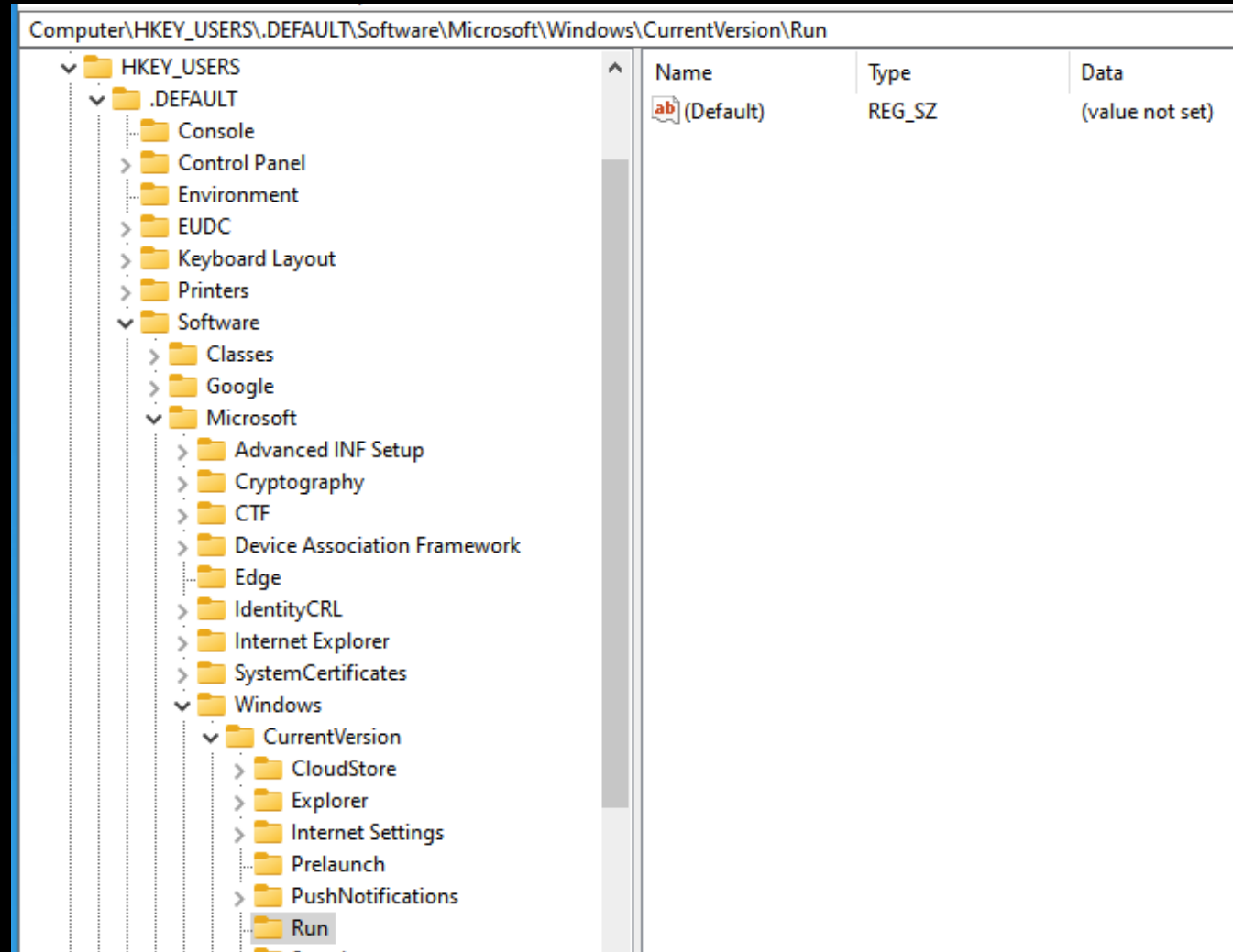
```
com.threat.plist — Edited
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN" "http://www.apple.com/
DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
  <key>Label</key>
  <string>com.threat</string>
  <key>ProgramArguments</key>
  <array>
    <string>Pun1sh3r</string>
    <string>{script_path}</string>
  </array>
  <key>RunAtLoad</key>
  <true/>
</dict>
</plist>
```

Windows

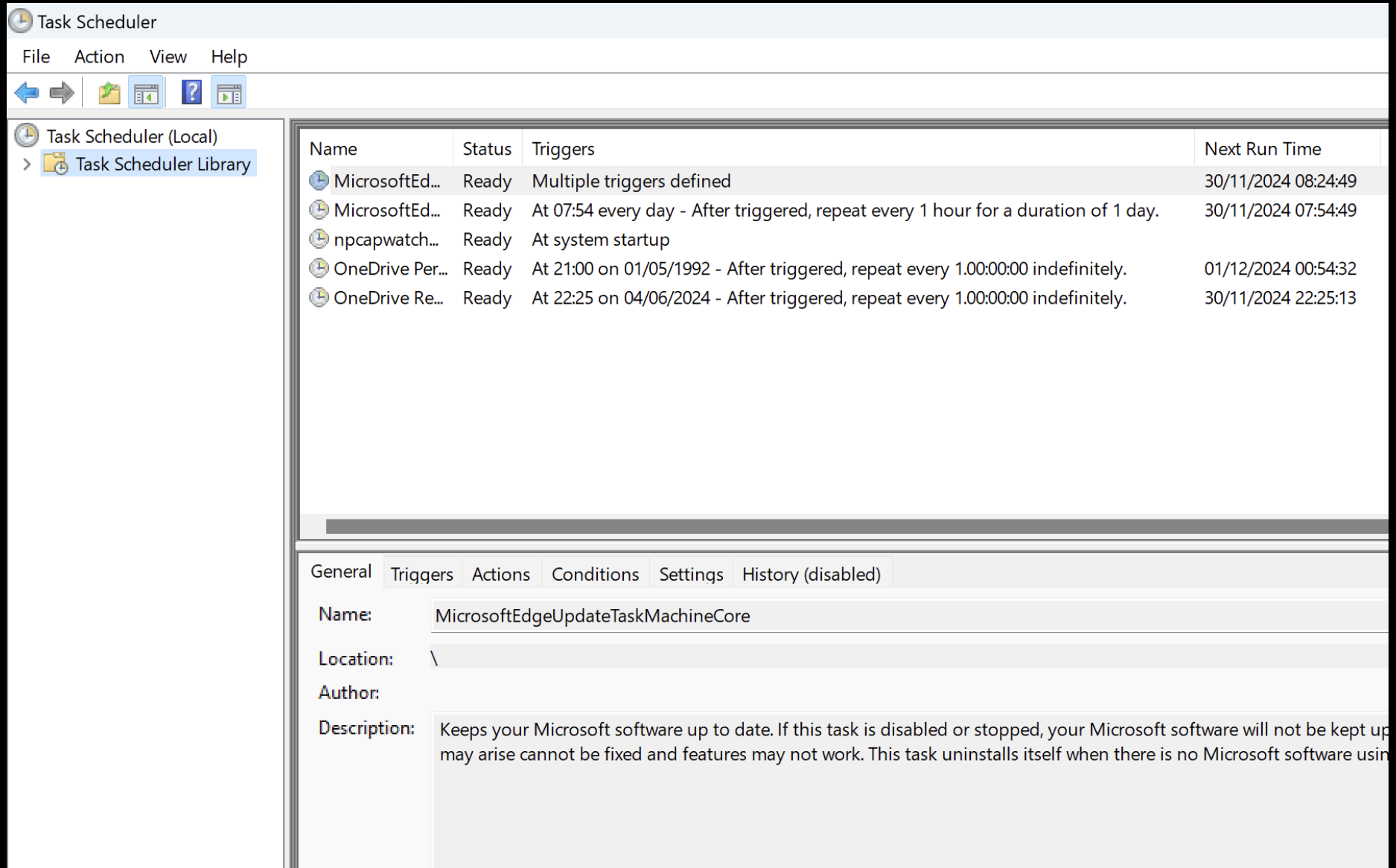
- Account Creation for Persistence
- Persistence Through Startup Folder
- **Registry Autorun**
- Hijack Default File Extension
- Persistence Using ShortCut Modification
- **Persistence Using Task Scheduler**

Windows - Register

Software\Microsoft\Windows\CurrentVersion\Run



Windows - Task Scheduler



Linux

- Account Creation for Persistence
- Persistence using SSH Authorized Keys
- **Persistence using Scheduled task**
- **Systemd Timers**
- Shell Configuration Modification
- Dynamic Linker Hijacking

Linux – Cron Jobs

```
root@debian-lab2:/home/pun1sh3r/vls# cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
```

Linux – Systemd Service

```
pun1sh3r@linux-lab03:~$ systemctl --user list-unit-files
```

UNIT FILE	STATE	PRESET
dbus.service	static	-
dirmngr.service	static	-
gpg-agent.service	static	-
ssh-agent.service	static	-
systemd-exit.service	static	-
systemd-tmpfiles-clean.service	static	-
systemd-tmpfiles-setup.service	disabled	enabled
app.slice	static	-
background.slice	static	-
session.slice	static	-
dbus.socket	static	-
dirmngr.socket	enabled	enabled
gpg-agent-browser.socket	enabled	enabled
gpg-agent-extra.socket	enabled	enabled
gpg-agent-ssh.socket	enabled	enabled
gpg-agent.socket	enabled	enabled
hdd.target	static	-

Let's put it in
practice

⚡ **SHOW-ME THE CODE!** ⚡



Conclusion And Recommendations

What should you do first?

- Preserve the chain of custody
- Discover patient zero
- Execute containment and eradication
- Investigate LOGs (FW, WAF, EDR, AV, AD)
- Find Persistence (Tasks / Registry / Services)

What should you do first?

- Lessons learned
- Hardening Tools
- Train your team (Threat Simulation)
- Check List Tools
- Telemetry check

Material

FileSystem

<https://developer.apple.com/library/archive/documentation/FileManagement/Conceptual/FileSystemProgrammingGuide/FileSystemOverview/FileSystemOverview.html>

LaunchAgentes

<https://support.apple.com/pt-br/guide/terminal/apdc6c1077b-5d5d-4d35-9c19-60f2397b2369/mac>

The Art Of Infection In MacOS

<https://hadess.io/the-art-of-infection-in-macos/>

The Art of Windows Persistence

<https://hadess.io/the-art-of-windows-persistenceebook/>

The Art of Linux Persistence

<https://hadess.io/the-art-of-linux-persistence/>

Lab Tools

Lab Tools

- Virtualizations
 - VMware Workstation
 - Windows 10
 - Debian 12
 - Parallels
 - MacOS (15.5 Sequoia)
 - MacOS (26.1 Tahoe)
- Python
- Java
- OBS Studio
- CapCut

Common questions?

- Did you present this to the manufacturers?
- Can an EDR really stop this type of attack?
- Did you use obfuscation or some other sophisticated technique in the code?
- Will you publish the code?

Questions?

Contacts

Telegram: @pun1sh3rx0
github.com/pun1sh3rx0
linkedin.com/in/zozielfreire

Thank you!

